

scripts/snyk-scan.sh — User Guide

Last verified: 2026-06-04 (completeness program, Phase 2C)

Inheritance: HelixConstitution §11.4.18 (script documentation mandate)

Overview

scripts/snyk-scan.sh is thin Lava-side glue that runs Snyk dependency (snyk test) and SAST (snyk code test) scans against the Gradle + Go projects using the containerized snyk/snyk image under a rootless runtime.

Per §6.U it NEVER uses sudo/su. Per §6.R the SNYK_TOKEN is read from .env (or the environment) and is NEVER hardcoded; interactive snyk auth is intentionally NOT used. Per §6.J it does not bluff: if SNYK_TOKEN is unset the script EXITS with a clear message rather than printing a fake pass.

Usage

```
./scripts/snyk-scan.sh           # deps + SAST scans (default)
./scripts/snyk-scan.sh deps      # dependency scan only
./scripts/snyk-scan.sh code      # SAST (snyk code) only
```

Prerequisites

- A rootless container runtime: **podman** (preferred) or **docker**.
- SNYK_TOKEN in .env. Obtain from <https://app.snyk.io/account> (Auth Token). Without it the script exits non-zero with an actionable message.

Outputs (per <date> under the evidence dir)

`.lava-ci-evidence/completeness-program/snyk/<date>/:`

- `deps-test.sarif` + `deps-test.log` — dependency scan results.
- `code-test.sarif` + `code-test.log` — SAST results.

Exit codes

Mirror Snyk's own semantics: 0 = no issues found, 1 = scan ran and issues were FOUND (a successful scan, not a script error), 2 = a hard error from the Snyk CLI. The `all` mode aggregates: 2 if either sub-scan errored, else 1 if either found issues, else 0.

`.snyk policy` file

The repo-root `.snyk` declares ignore + patch directives. It ships with empty ignore: `{}` / patch: `{}`; every future ignore MUST carry a reason + expiry so suppressions don't silently hide a real vulnerability.

Maintenance

When this script changes, update this document in the same commit (CM-SCRIPT-DOCS-SYNC, §11.4.18).

Cross-references

- `scripts/snyk-scan.sh` — the script itself
- `.snyk` — ignore / patch policy
- `docs/security/2026-06-04-sonarqube-snyk-setup.md` — full setup + blockers